

PENETRATION TESTING FUNDAMENTALS

MODULE 2

Planning & Scoping a Pen Testing Assessment

Student Study Guide

Topics covered: Regulatory Compliance · Contracts · Rules of Engagement · Scope Management · Risk · Testing Strategy

1. Introduction to Planning & Scoping

One of the most important phases — if not the most important — of any penetration testing engagement is the planning and preparation phase. During this phase, you clearly scope your engagement. Failure to scope correctly will cause issues with your client (if you work as a consultant) or your employer (if you are part of a corporate red team), and you might even encounter legal problems.

 KEY CONCEPT

Scope creep is one of the leading causes of failed pen testing engagements. Getting the scope right from the start protects you legally, financially, and professionally.

Key Concepts You Must Address

- The target audience
- The rules of engagement
- The communication escalation path and communication channels
- The available resources and requirements
- The overall budget for the engagement
- Any specific disclaimers
- Any technical constraints
- The resources available to you as a penetration tester

Red Team vs. Blue Team

Red Team	Blue Team
A group of cybersecurity experts and penetration testers hired to mimic a real threat actor — exposing vulnerabilities and risks in technology, people, and physical security.	The corporate security team that defends the organization: SOC analysts, CSIRTs, InfoSec teams, and others.

2. Regulatory Compliance Considerations

You must be familiar with several regulatory compliance considerations to be successful in ethical hacking and penetration testing — not only to complete compliance-based assessments, but also to understand what regulations may affect you and your client.

KEY CONCEPT

Penetration testing = the technical action to find and exploit weaknesses. Compliance-based assessment = the guidelines and rules telling you WHEN to test, WHAT to test, HOW OFTEN to test, and what the results should look like (e.g. no critical vulnerabilities).

2.1 PCI DSS

The Payment Card Industry Data Security Standard (PCI DSS) aims to secure the processing of credit card payments and other types of digital payments.

- Applies to any organization that processes, stores, or transmits cardholder data
- Provides checklists for items that should be assessed during a pen testing engagement
- Reference: pcisecuritystandards.org

2.2 HIPAA

The Health Insurance Portability and Accountability Act of 1996 (HIPAA) was originally intended to simplify and standardize healthcare administrative processes — transitioning from paper to electronic records. The U.S. Department of Health and Human Services (HHS) developed standards to protect electronic health information while permitting appropriate access.

- Protects individually identifiable health information (PHI / ePHI)
- Requires security risk analysis and risk management processes
- Reference: cdc.gov/phlp

2.3 FedRAMP

The Federal Risk and Authorization Management Program (FedRAMP) is the U.S. federal government standard for authorizing the use of cloud service offerings.

- Mandatory for cloud services used by U.S. federal agencies
- Provides a standardized approach to security assessment and authorization

- Reference: [fedramp.gov](https://www.fedramp.gov)

2.4 GDPR

The General Data Protection Regulation (GDPR) includes strict rules around the processing of data and privacy. One of its main goals is to strengthen and unify data protection for individuals within the European Union (EU), while addressing the export of personal data outside the EU.

- Primary objective: give citizens control of their personal data
- Strict breach notification requirements — 72-hour notification window
- Applies to any organization processing EU residents' data, regardless of where the org is based
- Reference: gdpr-info.eu

NOTE

Compliance-based assessments provide standards (like PCI DSS) that guide when and how penetration testing should be performed.

2.5 CCPA

The California Consumer Privacy Act (CCPA) is a U.S. state law focused on privacy, giving California consumers rights over their personal data.

- Right to know what personal data is being collected
- Right to delete personal information held by a business
- Right to opt out of the sale of personal information
- Reference: oag.ca.gov/privacy/ccpa

3. Key Technical Elements in Regulations

Most regulations dictate several key elements that a penetration tester must verify during an assessment to confirm the organization is compliant.

3.1 Data Isolation

Organizations that need to comply with PCI DSS (and similar regulations) should have a data isolation strategy — also known as network isolation or network segmentation.

- Goal: implement a completely isolated network containing all systems involved in payment card processing
- Prevents lateral movement from untrusted network segments into the cardholder data environment (CDE)
- A pen tester should verify that the isolation is properly implemented and enforced

3.2 Password Management

Most regulations mandate solid password management strategies.

- Organizations must not use vendor-supplied defaults for system passwords and security parameters
- Regulations typically mandate password length, complexity, and session timeout requirements
- Multi-factor authentication (MFA) is increasingly required by most modern standards
- This requirement extends into the broader realm of configuration management

3.3 Key Management

Key management policy and standards are critical elements of any compliance framework.

- Assign clear responsibility for key management
- Define the nature of information to be protected and the classes of threats
- Specify the cryptographic protection mechanisms to be used
- Define the protection requirements for keys and associated processes

 NOTE

NIST provides comprehensive key management guidelines at: csrc.nist.gov/projects/key-management/key-management-guidelines

4. Local Restrictions & Legal Considerations

You should be aware of any local restrictions when hired to perform penetration testing. For instance, you may travel to a country where specific laws restrict certain tasks as a penetration tester. Penetration testing laws vary from country to country.

 IMPORTANT

Some penetration testers have been accused and even arrested for allegedly violating the Computer Fraud and Abuse Act (CFAA) — Section 1030(a)(5)(B). Always carry clear written documentation from your client indicating you have permission to perform testing.

Common Testing Constraints

- Certain areas and technologies that cannot be tested due to operational limitations (e.g. no SQL injection against production databases, as it may corrupt live data)
- Technologies specific to the organization being tested
- Limitation of the team's skill sets
- Limitation of known exploits for a given environment
- Systems categorized as out of scope due to criticality or known performance problems

You should clearly communicate any technical constraints to the appropriate stakeholders before and during testing. Local government requirements such as GDPR and CCPA may also impose additional constraints.

5. Contracts

The contract is one of the most important documents in a pen testing engagement. It specifies the terms of the agreement, how you will get paid, and provides clear documentation of the services to be performed. A contract should be very specific, easy to understand, and without ambiguities.

 IMPORTANT

Any ambiguities in the contract will likely lead to customer dissatisfaction and friction. Legal advice from a lawyer is always recommended.

Critical Contract Elements

- Specific, unambiguous terms of service and payment
- Data residency requirements — a client may specify that collected information cannot leave the country where testing occurred
- PII restrictions — the tester cannot remove personally identifiable information that may be subject to laws or regulations without written authorization
- Signed by a proper signing authority — obtain written authorization for the work to be performed
- Third-party authorization — written authorization from ISPs, cloud providers, or any other external entity impacted by the test

KEY CONCEPT

The contract should not permit more risk than it is intended to resolve. The client's legal department will typically review the contract with this in mind.

6. Disclaimers

Add disclaimers to your pre-engagement documentation as well as in the final report. Disclaimers protect you legally and set clear expectations for the client.

Standard Disclaimers to Include

1. Testing was conducted on the applications and systems that existed as of a clearly stated date — cybersecurity threats change daily and new vulnerabilities are discovered constantly.
2. The report is intended only to provide documentation — the client determines the best remediation approach.
3. The report cannot protect against personal or business loss resulting from use of the systems described.
4. No warranties, representations, or legal certifications are made concerning the tested applications or systems.
5. The report does not represent that any system tested is suitable for a given task or free of defects other than those reported.
6. The report does not claim systems are fully compliant with any industry standard or compatible with any OS, hardware, or application.

 NOTE

Consider hiring a lawyer to help create and customize your contracts and disclaimers as needed.

7. Rules of Engagement (ROE)

A Rules of Engagement (ROE) document outlines the specific guidelines, protocols, and limitations that govern how individuals or groups should behave during a penetration testing engagement. The ROE specifies conditions under which the engagement will be conducted and must be documented and agreed upon with the client.

Common ROE Elements

ROE Element	Example
Testing Timeline	Three weeks, as specified in a Gantt chart
Location of Testing	Company's headquarters in Raleigh, NC
Time Window (hours of day)	9:00 AM to 5:00 PM EST
Communication Method	Final report and weekly status update meetings
Security Controls That May Detect Testing	IPS, firewalls, DLP systems
IP Addresses for Test Origin	10.10.1.0/24, 192.168.66.66, 10.20.15.123
Allowed / Disallowed Tests	Web apps only; no social engineering; SQL injection only in dev/stage environments

8. Target List & In-Scope Assets

Scoping is one of the most important elements of any penetration testing engagement. You must carefully identify and document all systems, applications, and networks to be tested and determine any

specific requirements needed to perform the test. The broader the scope, the more skills and resources that will be needed.

What to Document

- IP address ranges of all devices and assets the tester is allowed to assess
- Wireless networks / SSIDs that are allowed — or not allowed — to be tested
- Fully Qualified Domain Names (FQDNs) of all in-scope applications and assets, including subdomains
- External vs. internal targets — clearly agree on whether you will test from an outside-attacker perspective and/or an insider threat perspective

Allow List vs. Deny List

Allow List	Deny List
A list of applications, systems, or networks that ARE in scope and should be tested.	A list of applications, systems, or networks that are NOT in scope and must NOT be tested.

8.1 API Documentation Types

When hired to perform an assessment of modern applications using APIs, your client may have the following types of documentation available:

API Type	Description
SOAP	Simple Object Access Protocol — relies on XML and XSD schemas. Having a good SOAP reference accelerates testing significantly. Spec: w3.org/TR/soap
Swagger (OpenAPI)	Modern framework for REST APIs and the basis of the OpenAPI Specification (OAS). These are the most common APIs today. swagger.io
WSDL	Web Services Description Language — an XML-based language documenting the functionality of a web service. Spec: w3.org/TR/wsdl20-primer

WADL	Web Application Description Language — XML-based language for describing web applications. Spec: w3.org/Submission/wadl
GraphQL	A modern query-based API alternative to REST, allowing clients to request exactly the data they need.

8.2 Cloud & Third-Party Hosted Applications

Understanding first-party vs. third-party hosted applications is very important. Applications today can be hosted in public cloud (AWS, GCP, Azure), private clouds, or hybrid clouds.

- A company can own a domain while its applications are entirely hosted by a cloud provider
- Some cloud providers require pre-authorization notifications before you can test their infrastructure
- Verify hosting arrangements before beginning testing — the scope and authorization may differ from what the client initially assumes

9. Scope Creep

Scope creep is a project management term that refers to the uncontrolled growth of a project's scope — also referred to as kitchen sink syndrome, requirement creep, or function creep.

IMPORTANT

Scope creep can put you out of business. Many security firms fail because they cannot identify when scope creep starts or how to respond to it.

Scope Creep Definition

Scope creep is when a project starts to go beyond its original goals or boundaries — usually little by little — without proper planning or approval. It often happens when new tasks, features, or requirements are added after the project has started, but weren't in the original plan or budget.

Common Causes of Scope Creep

- **Change Management:** Poor Change Management — inadequate change control processes during the engagement
- **Technical & Nontechnical Elements:** Ineffective identification of what technical and nontechnical elements will be required for the test
- **Poor Communication:** Inadequate communication among stakeholders, including your client and your own team

KEY CONCEPT

Scope creep doesn't always start negatively. A satisfied client may ask for additional testing — which is great business, but always formalize extra work with a new, signed Statement of Work (SOW). Never expand scope silently.

If you initially engaged with your client after a request for proposal (RFP), and additional work is needed that was not part of the RFP or your initial SOW, ask for a new SOW to be signed and agreed upon before beginning that additional work.

10. Validating the Scope of Engagement

The first step in validating the scope of an engagement is to question the client and review contracts. You must understand who the target audience is for your penetration testing report and identify all subjects, business units, and entities to be assessed.

Target Audience Questions

Question	Why It Matters
Who is the primary recipient of the report?	Different audiences need different levels of technical detail.
What is the recipient's position in the organization?	Determines the authority level and scope of decisions they can make.
What is the main purpose and goal of the engagement?	Shapes priorities and focus of the testing.

Who has responsibility and authority to act on findings?	Critical for ensuring findings result in actual remediation.
Who else will have access to the report?	CISO, CIO, CTO, InfoSec teams, technical teams, etc.
Will access be on a need-to-know basis?	The report contains sensitive information that must be protected.

Stakeholder Communication Documentation

You should always have good, open lines of communication with the clients and stakeholders who hired you. Document the answers to these questions:

- Relevant stakeholders: What is the contact information for all relevant stakeholders?
- Communication process: How will you communicate with the stakeholders?
- Timing of interaction: How often do you need to interact with the stakeholders?
- Emergency contact: Who can be contacted at any time if an emergency arises?

NOTE

Ask for a form of secure bulk data transfer or storage such as Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP). Also exchange PGP keys or S/MIME keys for encrypted email communication.

11. Professionalism & Integrity

There are many scenarios in which an ethical hacker (penetration tester) must demonstrate professionalism and integrity. The following are critical best practices:

11.1 Background Checks

A client may require that you and your team undergo careful background checks, depending on the environment and engagement. Organizations sometimes require these to feel comfortable allowing access to their environment and information.

11.2 Adherence to Scope

You have already learned about the importance of proper scoping. Honor allow lists (in-scope systems) and deny lists (out-of-scope systems) precisely as agreed. The organization creates these lists carefully — always obey them.

11.3 Identification of Criminal Activity

In some cases, you may discover that a real attacker has already compromised the client's systems. You must identify any criminal activities and report them immediately — do not continue testing in a compromised environment without notifying the client first.

11.4 Limiting the Use of Tools

In some engagements, you will not be allowed to use certain tools due to legal reasons or because those tools could bring down the network and underlying systems. Always clarify tool restrictions in the ROE before testing begins.

11.5 Limiting Invasiveness Based on Scope

Some tools and attacks could be extremely disruptive to your client's systems and mission. You should always limit the verbosity and invasiveness of your tests and tools based on the agreed scope. Active and passive reconnaissance differ significantly in their impact on systems.

11.6 Confidentiality

The results of the penetration testing engagement (the report) and all information gathered during the engagement must be protected and kept strictly confidential. If this information is lost or shared, it could be used by an adversary to cause significant damage to your client.

11.7 Risk to the Professional

If you do not adhere to these best practices, you could face fees, fines, and in some cases even criminal charges. Companies and individuals conducting professional penetration testing should carry general business liability insurance.

 IMPORTANT

In order to have a strong cybersecurity program, business objectives must take into account risk tolerance and the resulting policies must be enforced and adopted across the organization.

12. Risk Tolerance & Risk Management

12.1 Risk Tolerance

Risk tolerance is how much of an undesirable outcome a risk-taker is willing to accept in exchange for the potential benefit. Inherently, risk is neither good nor bad — all human activity carries some risk.

 KEY CONCEPT

Think of it this way: every time you drive a car, you accept some risk. You manage that risk by wearing a seatbelt, obeying traffic laws, and staying alert. You accept the risk because the reward (reaching your destination) outweighs the potential harm. The same logic applies to organizational risk decisions.

Risk-taking can be beneficial and is often necessary for advancement — entrepreneurial risk-taking can pay off in innovation and progress. However, risk-taking can be detrimental when influenced by ignorance, ideology, dysfunction, greed, or revenge. The key is to balance risk against rewards by making informed decisions.

12.2 Risk Management Process

Risk management is the process of:

7. Determining an acceptable level of risk (risk appetite and tolerance)
8. Calculating the current level of risk (risk assessment)
9. Accepting the level of risk (risk acceptance)

10. Or taking steps to reduce risk to an acceptable level (risk mitigation)

NOTE

Risk acceptance indicates the organization is willing to accept the level of risk associated with a given activity. Even when risk is outside tolerance, an organization may still choose to accept it if all alternatives are unacceptable — but this must be authorized by executive management or the board of directors.

13. Budget & Return on Investment (ROI)

Questions about budget and ROI may arise from both the client side and the tester side in every pen testing engagement.

Client-Side Questions

- Cost Justification: How do I explain the overall cost of penetration testing to my boss?
- Need for Pen Testing: Why do we need it if we already have security controls in place?
- Success Factor: How do I build pen testing in as a success factor?
- Need for External Vendor: Can I do it myself with internal staff?
- Return on Investment: How do I calculate the ROI for the engagement?

Tester-Side Questions

- Budget Concerns: How do I account for all items to avoid going over budget?
- Pricing: How do I price the engagement fairly and accurately?
- Demonstrate ROI: How can I clearly show ROI to my client?

The answers to these questions depend on how effectively you scope the engagement and clearly communicate all elements. Another factor is understanding that penetration testing is a point-in-time assessment.

13.1 Point-in-Time Assessment

Penetration testing is a snapshot — not a guarantee of ongoing security. Consider this real-world example of 3 engagements over 2 years at the same organization:

Engagement	Critical / High / Medium / Low
Year 1 — 1,000 systems assessed	5 Critical · 11 High · 32 Medium · 45 Low
Year 2 — 1,100 systems assessed	3 Critical · 31 High · 10 Medium · 7 Low
Year 3 (+2 yrs) — 2,200 systems assessed	15 Critical · 22 High · 8 Medium · 15 Low

Is the company doing better or worse? Are engagements done purely for compliance? The key insight is that penetration testing alone cannot guarantee the overall security of the company. The tester must incorporate clear and achievable mitigation strategies for vulnerabilities found, along with appropriate impact analysis and remediation timelines.

14. Testing Strategy: Unknown vs. Known Environment

When discussing penetration testing strategies, you will hear two key terms that describe the perspective from which testing is performed and how much information is provided to the tester.

Unknown-Environment Testing	Known-Environment Testing
Formerly called black-box testing. The tester is given very limited information — typically only domain names and IP addresses in scope. The idea is to simulate an external attacker who has no prior knowledge of the target.	Formerly called white-box testing. The tester starts with significant information: network diagrams, IP addresses, configurations, and user credentials. For application assessments, source code may also be provided.
Network support staff may not even know the exact timing of the test — allowing a real defense exercise. Scope is typically broader: internal network auditing, desktop scanning.	Goal: identify as many security holes as possible. Scope may be narrow — e.g. find just one path into the organization. Ideal when the client has specific concerns about a particular application or segment.



KEY CONCEPT

Time and money are the typical deciding factors for which strategy to choose. If a company has specific concerns about an application, server, or infrastructure segment, it can provide targeted information to decrease scope — while still uncovering desired results. Given the sophistication of modern adversaries, most networks will be compromised at some point. An unknown-environment testing approach is often the better choice for a realistic view of your security posture.

15. Module Summary & Key Takeaways



REMEMBER

Planning and scoping is the most critical phase of any pen testing engagement. Get it right, and every subsequent phase runs smoothly.

Key Takeaways

11. Plan before you test — scoping mistakes lead to client conflict and legal risk.
12. Know your regulations — PCI DSS, HIPAA, FedRAMP, GDPR, and CCPA shape what and how you test.
13. Contracts and ROE are essential — clear, unambiguous documentation protects everyone.
14. Watch for scope creep — manage change formally and get a new SOW when scope grows.
15. Communicate constantly — know your audience, stakeholders, and escalation paths.
16. Choose the right strategy — unknown- vs. known-environment testing depends on goals, time, and budget.
17. Pen testing is a point-in-time assessment — not a guarantee of security. Always pair findings with clear mitigation strategies.

Quick Reference: Regulations

Regulation	Purpose & Scope
PCI DSS	Secures credit/digital payment processing. Requires network segmentation, MFA, strong passwords.

HIPAA	Protects electronic health information. Requires risk analysis and security safeguards.
FedRAMP	Authorizes cloud services for U.S. federal government use.
GDPR	EU data protection law. Gives citizens control of personal data. 72-hour breach notification.
CCPA	California state privacy law. Consumer rights over their personal data.

End of Module 2
